SYSTEM ARCHITECTURE & SECURITY SPECIFICATION

LearnLink - Access Control List (ACL) & System Architecture

เอกสารกำหนดรายการทรัพย์สิน โครงสร้างสถาปัตยกรรมระบบ และนโยบายควบคุมสิทธิ์การเข้าถึง (ฉบับปรับปรุง 3 บทบาทผู้ใช้งาน)

Project	LearnLink - Social Learning Community	**Version**	1.4 (Updated - 3 User Roles)
Document	Asset List, System Architecture & ACL	**Status**	For Development Team

3. Asset List

Asset List คือรายการทรัพย์สินที่มีความสำคัญต่อระบบและต้องได้รับการปกป้อง โดยแบ่งออกเป็น Information Assets, Software Assets และ Infrastructure Assets

3.1 Information Assets

Asset ID	Asset Name	รายละเอียด	ระดับความสำคัญ
A-01	User Account	ข้อมูลบัญชีผู้ใช้งาน (Member, Community Owner และ Admin)	สูง
A-02	Password	รหัสผ่านของผู้ใช้งาน	สูงมาก
A-03	Profile Information	ชื่อ ประวัติ และข้อมูลโปรไฟล์	ปานกลาง
A-04	Profile Image	รูปโปรไฟล์	ปานกลาง
A-05	Post Content	ข้อมูลโพสต์	ปานกลาง
A-06	Follow Relationship	ความสัมพันธ์การติดตาม	ปานกลาง
A-07	Database	ฐานข้อมูลทั้งหมด	สูงมาก
A-08	Environment Variables	ข้อมูลการตั้งค่าและ Secret	สูงมาก
A-09	Security Logs	บันทึกเหตุการณ์ด้านความปลอดภัย	สูง

3.2 Software Assets

Asset ID	Software Asset	รายละเอียด	ระดับความสำคัญ
S-01	Django Backend	ระบบประมวลผลหลักฝั่ง Server	สูงมาก
S-02	Authentication Module	ระบบสมัครสมาชิก เข้าสู่ระบบ และออกจากระบบ	สูงมาก
S-03	User Module	ระบบจัดการบัญชีผู้ใช้งาน	สูง
S-04	Profile Module	ระบบจัดการข้อมูลและรูปโปรไฟล์	ปานกลาง

Asset ID	Software Asset	รายละเอียด	ระดับความสำคัญ
S-05	Community Module	ระบบจัดการชุมชนและพื้นที่การเรียนรู้	สูง
S-06	Post Module	ระบบจัดการโพสต์	สูง
S-07	Feed Module	ระบบแสดงรายการโพสต์	สูง
S-08	Follow Module	ระบบติดตามและเลิกติดตามผู้ใช้งาน	ปานกลาง
S-09	Like Module	ระบบกดถูกใจโพสต์	ปานกลาง
S-10	Comment Module	ระบบแสดงความคิดเห็นต่อโพสต์	สูง
S-11	Media Module	ระบบจัดการไฟล์และรูปภาพ	สูง
S-12	Security Module	ระบบตรวจสอบตัวตนและควบคุมสิทธิ์	สูงมาก
S-13	Database System	ระบบจัดเก็บและจัดการข้อมูล	สูงมาก

3.3 Infrastructure Assets

Asset ID	Infrastructure Asset	รายละเอียด	ระดับความสำคัญ
I-01	Application Server	เครื่องให้บริการ Django Application	สูงมาก
I-02	Database Server	เครื่องให้บริการฐานข้อมูล	สูงมาก
I-03	File Storage	พื้นที่จัดเก็บไฟล์และรูปภาพ	สูง
I-04	GitHub Repository	แหล่งจัดเก็บ Source Code และประวัติการพัฒนา	สูง
I-05	Environment Configuration	ไฟล์กำหนดค่าระบบและข้อมูล Secret	สูงมาก
I-06	Network Infrastructure	ระบบเครือข่ายที่ใช้รับส่งข้อมูลระหว่าง Client และ Server	สูง
I-07	Development Environment	เครื่องมือและสภาพแวดล้อมที่ใช้พัฒนาระบบ	ปานกลาง
I-08	Backup Storage	พื้นที่จัดเก็บข้อมูลสำรอง	สูงมาก

เกณฑ์การกำหนดระดับความสำคัญ

ระดับ	ความหมาย
สูงมาก (Critical)	หากสูญหายหรือถูกโจมตี อาจส่งผลกระทบร้ายแรงต่อระบบและข้อมูลสำคัญ
สูง (High)	หากเกิดความเสียหาย จะกระทบต่อความปลอดภัยหรือการทำงานหลักของระบบ
ปานกลาง (Medium)	หากเกิดความเสียหาย จะกระทบต่อการทำงานบางส่วน แต่ยังสามารถดำเนินงานส่วนอื่นได้
ต่ำ (Low)	ทรัพย์สินที่มีผลกระทบต่อระบบค่อนข้างน้อย

3.4 Asset Protection Requirements

Asset	Confidentiality	Integrity	Availability
Password	สูงมาก	สูงมาก	สูง
User Account	สูง	สูง	สูง
Profile	ปานกลาง	สูง	ปานกลาง
Posts	ปานกลาง	สูง	สูง
Database	สูงมาก	สูงมาก	สูงมาก
Environment Variables	สูงมาก	สูงมาก	สูงมาก
Security Logs	สูง	สูง	ปานกลาง
Community Data	ปานกลาง	สูง	สูง
Like Data	ปานกลาง	สูง	ปานกลาง
Comment Data	ปานกลาง	สูง	สูง
Media Files	ปานกลาง	สูง	สูง

4. System Architecture

สถาปัตยกรรมระบบของ LearnLink ออกแบบในรูปแบบ **สถาปัตยกรรมแบบเลเยอร์ (Layered Architecture)** จำนวน 4 ชั้น (4 Layers) เพื่อช่วยให้ระบบมีโครงสร้างที่ชัดเจน แยกการรับผิดชอบตามหน้าที่อย่างเป็นสัดส่วน และเป็นพื้นฐานของการออกแบบเชิง Component (Component Design) โดยควบคุมการเข้าถึงและสิทธิ์ความปลอดภัย (Security & ACL) อย่างเป็นระบบในแต่ละชั้น

4.1 Architecture Overview (4-Layer Architecture)

ชั้นสถาปัตยกรรม (Layer)	หน้าที่และความรับผิดชอบหลัก
1. Presentation Layer (UI / Views / API Endpoints)	เป็นส่วนติดต่อผู้ใช้ (User Interface / Web Browser / REST API Views) ทำหน้าที่รับคำสั่งจากผู้ใช้งาน ตรวจสอบรูปแบบข้อมูลเบื้องต้น และแสดงผลลัพธ์กลับไปยังผู้ใช้
▼ ส่งคำสั่ง (Request / Input)	
2. Application Layer (Use Cases & Security Orchestration)	ควบคุมลำดับการทำงาน (Workflow) รับคำสั่งจาก Presentation Layer ตรวจสอบสิทธิ์การเข้าถึง (Authentication, Authorization, Permission & Ownership) แล้วเรียกใช้ Domain Layer และ Infrastructure Layer ตามลำดับ
▼ เรียกใช้กฎเกณฑ์และตรรกะหลัก	
3. Domain Layer (Core Business Entities & Rules)	ชั้นแกนกลางของระบบที่จัดการองค์ประกอบหลัก ทั้งข้อมูล พฤติกรรม และกฎเกณฑ์ทางธุรกิจ (User, Profile, Community, Post, Feed, Follow, Like, Comment, Media) โดยไม่ขึ้นตรงกับฐานข้อมูลหรือระบบภายนอก
▼ เรียกผ่าน Interface	
4. Infrastructure Layer (Database, File Storage & External Services)	จัดการการเชื่อมต่อกับฐานข้อมูล (Django ORM / Relational Database), ระบบจัดเก็บไฟล์ (File Storage), บริการภายนอก (External APIs) และระบบบันทึก Security Logs

4.2 รายละเอียดหน้าที่ความรับผิดชอบของแต่ละ Layer

Layer	บทบาทหลัก	รายละเอียดการทำงานและขอบเขตหน้าที่
1. Presentation Layer (UI / Views / API)	ส่วนติดต่อผู้ใช้	• แสดงผลหน้าจอ (UI) และรับคำสั่งจากผู้ใช้งานผ่าน HTTP/HTTPS Request • ตรวจสอบความถูกต้องของรูปแบบข้อมูลรับเข้า (Input Serialization / Validation) เบื้องต้น • ส่งต่อคำสั่งไปยัง Application Layer และแสดงผล Response กลับสู่ผู้ใช้งาน
2. Application Layer (Application Services & Security)	ควบคุมลำดับการทำงานและสิทธิ์	• รับคำสั่งจาก Presentation Layer แล้วเรียกใช้ Domain Layer และ Infrastructure Layer ตามลำดับ • บังคับใช้ Security Controls ส่วนกลาง (Authentication, Authorization, ACL Permission และ Ownership Validation) ก่อนเริ่มกระบวนการ • ไม่เก็บ Business Logic เชิงลึกไว้โดยตรง แต่เรียกใช้ Logic จาก Domain Layer • ไม่เข้าถึงฐานข้อมูลหรือระบบภายนอกโดยตรง แต่เรียกผ่าน Interface ที่ Infrastructure Layer เป็นผู้ Implement
3. Domain Layer (Core Business Entities)	แกนกลางตรรกะและกฎเกณฑ์ของระบบ	• จัดการองค์ประกอบหลัก (Entities) ข้อมูล พฤติกรรม และกฎเกณฑ์ทางธุรกิจของ LearnLink (User, Profile, Community, Post, Feed, Follow, Like, Comment, Media) • กำหนดเงื่อนไขเฉพาะของโดเมน เช่น ห้ามติดตามตนเอง, ห้ามกด Like ซ้ำ, สถานะ Public/Private ของ Community • แยกเป็นอิสระจากเทคโนโลยีฐานข้อมูลและโครงสร้างพื้นฐานภายนอก
4. Infrastructure Layer (Database & External Services)	จัดการฐานข้อมูลและบริการภายนอก	• Implement Interface สำหรับเชื่อมต่อและจัดการข้อมูลในฐานข้อมูลผ่าน Django ORM • จัดการระบบจัดเก็บไฟล์และรูปภาพ (Media / File Storage) และการตรวจสอบไฟล์จริง • เชื่อมต่อบริการภายนอก (External APIs) รวมถึงการบันทึกเหตุการณ์ด้านความปลอดภัย (Security Logging)

4.3 Request Flow (ลำดับการไหลของคำร้องขอทั้ง 4 Layers)

ลำดับ	Layer	ขั้นตอนการทำงาน
1	Presentation Layer	ผู้ใช้งานส่ง Request ผ่านหน้า UI หรือ API Endpoint ระบบตรวจสอบรูปแบบข้อมูลเบื้องต้นแล้วส่งต่อไปยัง Application Layer
2	Application Layer	ตรวจสอบตัวตน (Authentication) ตรวจสอบสิทธิ์ตามบทบาท (Authorization / ACL ของ Member, Community Owner และ Admin) และความเป็นเจ้าของข้อมูล (Ownership)
3	Domain Layer	ประมวลผลกฎเกณฑ์ทางธุรกิจ (Business Rules) และตรวจสอบความถูกต้องตามเงื่อนไขของ Entities ที่เกี่ยวข้อง
4	Infrastructure Layer	บันทึกหรือดึงข้อมูลผ่าน Django ORM / File Storage และบันทึก Security Log ที่เกี่ยวข้อง
5	Application → Presentation	Application Layer รวบรวมผลลัพธ์ส่งกลับไปยัง Presentation Layer เพื่อแสดงผลหรือตอบกลับ (Response) ให้ผู้ใช้งาน

4.4 หลักการควบคุมความปลอดภัยในสถาปัตยกรรมแบบ 4 Layers

ข้อที่	หลักการ	แนวทางปฏิบัติในแต่ละ Layer
1	Strict Layer Dependency	Presentation Layer เรียกใช้ได้เฉพาะ Application Layer และห้ามข้ามไปเรียก Domain หรือ Infrastructure Layer โดยตรง
2	Centralized Access Control	การตรวจสอบสิทธิ์ (ACL) และ Ownership ต้องดำเนินการใน Application Layer ก่อนเรียกใช้ Domain Layer เสมอ
3	Server-Side Enforcement	การตรวจสอบสิทธิ์ทั้งหมดต้องบังคับใช้ที่ฝั่ง Server และห้ามใช้การซ่อนเมนูใน Presentation Layer เพียงอย่างเดียว
4	Domain Isolation	Domain Layer ต้องรักษาความถูกต้องของกฎเกณฑ์ทางธุรกิจโดยไม่ผูกติดกับรายละเอียดของ Database หรือ External APIs
5	Interface Abstraction	Application Layer เรียกใช้งานฐานข้อมูลและบริการภายนอกผ่าน Interface ที่ Infrastructure Layer เป็นผู้ Implement
6	Least Privilege & Default Deny	กำหนดสิทธิ์เท่าที่จำเป็นในทุก Layer และปฏิเสธการเข้าถึงโดยอัตโนมัติหากไม่มีสิทธิ์อนุญาตอย่างชัดเจน

5. Access Control List (ACL)

Access Control List เป็นข้อกำหนดว่าผู้ใช้งานแต่ละประเภทสามารถเข้าถึงข้อมูลหรือดำเนินการใดในระบบได้บ้าง โดยระบบ LearnLink กำหนดบทบาทผู้ใช้งานไว้ **3 ประเภท** ได้แก่ **Member**, **Community Owner** และ **Admin**

5.1 User Roles

Role ID	Role	รายละเอียด	ระดับสิทธิ์
R-01	**Member**	สมาชิกทั่วไปของระบบที่เข้าสู่ระบบแล้ว สามารถใช้งานพื้นที่การเรียนรู้ สร้างโพสต์ แสดงความคิดเห็น ติดตามผู้ใช้ และเข้าร่วม Community ได้	User Access
R-02	**Community Owner**	สมาชิกที่เป็นผู้สร้างและดูแลจัดการ Community ของตนเอง มีสิทธิ์จัดการตั้งค่า สมาชิก และดูแลความเรียบร้อยของเนื้อหาภายใน Community ที่ตนเองเป็นเจ้าของ	Community Management Access
R-03	**Admin**	ผู้ดูแลระบบทั้งหมด (Administrator) มีสิทธิ์จัดการบัญชีผู้ใช้งาน Community เนื้อหาทั้งหมด บันทึกความปลอดภัย และการตั้งค่าระบบ	Full System Access

> **หมายเหตุ**
>
> ระบบกำหนดประเภทผู้ใช้งาน 3 บทบาทหลักคือ **Member**, **Community Owner** และ **Admin** โดย Member ที่สร้าง Community จะได้รับสิทธิ์เป็น Community Owner ของ Community นั้นโดยอัตโนมัติ และ Admin มีสิทธิ์ดูแลจัดการระบบทั้งหมด

5.2 Permission Definition

Permission	ความหมาย	ตัวอย่าง
Allow	อนุญาตให้ดำเนินการ	Member ดู Feed และสร้างโพสต์ / Admin จัดการระบบ
Deny	ไม่อนุญาตให้ดำเนินการ	Member แก้ไขหรือลบ Community ของผู้อื่นไม่ได้
Own Only	ดำเนินการได้เฉพาะข้อมูลหรือรายการที่ตนเองสร้าง	Member แก้ไขหรือลบโพสต์ของตนเอง
Scoped	ดำเนินการได้เฉพาะขอบเขต Community ที่ตนเองเป็นเจ้าของ	Community Owner ลบโพสต์หรือความคิดเห็นภายใน Community ของตนเอง

5.3 Permission Matrix

Function	Member	Community Owner	Admin
Register	**Deny** (สำหรับผู้ที่ลงทะเบียนแล้ว)	**Deny** (สำหรับผู้ที่ลงทะเบียนแล้ว)	**Deny** (สำหรับผู้ที่ลงทะเบียนแล้ว)
Login	**Allow**	**Allow**	**Allow**
Logout	**Own Only**	**Own Only**	**Allow**
View Public Feed	**Allow**	**Allow**	**Allow**
View Public Profile	**Allow**	**Allow**	**Allow**
Edit Own Profile	**Own Only**	**Own Only**	**Allow**
Edit Other Profile	**Deny**	**Deny**	**Allow**
Create Post	**Allow**	**Allow**	**Allow**
View Public Post	**Allow**	**Allow**	**Allow**
Edit Own Post	**Own Only**	**Own Only**	**Allow**
Delete Own Post	**Own Only**	**Own Only**	**Allow**
Delete Other Post	**Deny**	**Scoped** (เฉพาะใน Community ของตน)	**Allow**
Create Community	**Allow** (ตามนโยบายระบบ)	**Allow** (ตามนโยบายระบบ)	**Allow**
View Community	**Allow** (ตามสถานะ Public/Private)	**Allow**	**Allow**
Edit Community	**Deny**	**Owner Only**	**Allow**
Delete Community	**Deny**	**Owner Only**	**Allow**
Like Post	**Allow**	**Allow**	**Allow**
Unlike Post	**Own Only**	**Own Only**	**Allow**
Create Comment	**Allow**	**Allow**	**Allow**

Function	Member	Community Owner	Admin
Edit Own Comment	**Own Only**	**Own Only**	**Allow**
Delete Own Comment	**Own Only**	**Own Only**	**Allow**
Delete Other Comment	**Deny**	**Scoped** (เฉพาะใน Community ของตน)	**Allow**
Follow User	**Allow**	**Allow**	**Allow**
Unfollow User	**Own Only**	**Own Only**	**Allow**
Upload Profile Image	**Own Only**	**Own Only**	**Allow**
View Security Logs	**Deny**	**Deny**	**Allow**
Manage User Roles	**Deny**	**Deny**	**Allow**
Manage System Settings	**Deny**	**Deny**	**Allow**

ข้อกำหนดเพิ่มเติม

- **Owner Only** หมายถึงผู้สร้างหรือเจ้าของข้อมูล หรือ Community Owner ที่เป็นเจ้าของ Community นั้นเท่านั้น
- **Scoped** หมายถึง Community Owner มีสิทธิ์ดูแลและจัดการเนื้อหา (เช่น ลบโพสต์หรือความคิดเห็นของผู้อื่น) เฉพาะภายในขอบเขต Community ที่ตนเองเป็นเจ้าของเท่านั้น
- **Admin** มีสิทธิ์จัดการข้อมูลทุกส่วน ผู้ใช้งาน Community บันทึกความปลอดภัย และการตั้งค่าระบบตามนโยบายระบบ
- การอนุญาตให้ Member อ่านโพสต์และเข้าถึง Community ต้องเป็นไปตามนโยบาย Public/Private ของระบบและของแต่ละ Community
- เมื่อ Member สร้าง Community สำเร็จ จะได้รับสถานะเป็น **Community Owner** สำหรับจัดการและดูแล Community ดังกล่าว

6. Module Access Control

ส่วนนี้กำหนดขอบเขตการทำงาน นโยบายการเข้าถึง และข้อกำหนดด้านความปลอดภัยของแต่ละ Module เพื่อให้ทีมพัฒนาสามารถนำไปอ้างอิงและดำเนินงานได้อย่างเป็นมาตรฐานภายใต้บทบาท **Member**, **Community Owner** และ **Admin**

6.1 Authentication Module

ขอบเขตการทำงาน	Register, Login, Logout, ตรวจสอบสถานะการเข้าสู่ระบบ
Access Policy	• ผู้ใช้งานใหม่สามารถสมัครสมาชิกเพื่อเริ่มต้นใช้งานในฐานะ Member และเข้าสู่ระบบได้ • Member, Community Owner และ Admin สามารถเข้าสู่ระบบและออกจากระบบของตนเองได้ • ผู้ใช้งานที่ยังไม่มี Authentication ไม่สามารถเข้าถึงข้อมูลและฟังก์ชันของระบบได้
Security Requirements	• เก็บรหัสผ่านด้วย Password Hashing และไม่เก็บรหัสผ่านแบบ Plain Text • ตรวจสอบความถูกต้องของข้อมูลก่อนสมัครสมาชิก • จำกัดความถี่ในการเข้าสู่ระบบ (Rate Limiting / Throttling) • ใช้ Session หรือ Token ที่มีความปลอดภัยเหมาะสม และไม่เปิดเผยข้อมูลบัญชีโดยไม่ได้รับอนุญาต

6.2 User / Profile Module

ขอบเขตการทำงาน	View Profile, Edit Profile, Update Profile Image, View Other Users
Access Policy	• Member, Community Owner และ Admin สามารถดูข้อมูลโปรไฟล์สาธารณะของผู้อื่นได้ • Member และ Community Owner แก้ไขโปรไฟล์ของตนเองได้ แต่ไม่สามารถแก้ไขโปรไฟล์ของผู้อื่น ยกเว้น Admin ที่สามารถจัดการข้อมูลผู้ใช้งานตามสิทธิ์ระบบได้ • การเปลี่ยนแปลงข้อมูลสำคัญต้องตรวจสอบสิทธิ์ทุกครั้ง
Security Requirements	• ตรวจสอบ Ownership หรือสิทธิ์ Admin ก่อนบันทึกการแก้ไขข้อมูลโปรไฟล์ • กรองข้อมูลส่วนตัวที่ไม่เปิดเผยต่อสาธารณะเมื่อผู้อื่นเรียกดูโปรไฟล์ • ป้องกันการเข้าถึงหรือแก้ไขข้อมูลข้ามบัญชี (IDOR)

6.3 Community Module

ขอบเขตการทำงาน	Create Community, View Community, Edit Community, Delete Community, Manage Community Information, Manage Community Members
Access Policy	• Member สามารถสร้าง Community ได้ตามนโยบายของระบบ โดยผู้สร้างจะได้รับสิทธิ์เป็น Community Owner ของ Community นั้น • Member ทั่วไปสามารถเข้าถึง Community ตามสถานะ Public/Private • Community Owner มีสิทธิ์แก้ไข ลบ ตั้งค่า และจัดการสมาชิกภายใน Community ที่ตนเองเป็นเจ้าของ และ Admin สามารถจัดการ Community ได้ทั้งหมด
Security Requirements	• ตรวจสอบสิทธิ์ความเป็น Community Owner หรือ Admin ก่อนแก้ไข ลบ หรือจัดการสมาชิก • ตรวจสอบสถานะ Public/Private ก่อนอนุญาตให้เข้าถึงข้อมูลภายใน • ป้องกันการเพิ่มหรือลบสมาชิกโดยไม่ได้รับอนุญาต และตรวจสอบข้อมูลก่อนสร้างหรือแก้ไข

6.4 Post Module

ขอบเขตการทำงาน	Create Post, View Post, Edit Post, Delete Post
Access Policy	• Member, Community Owner และ Admin ที่เข้าสู่ระบบแล้วสามารถสร้างโพสต์ได้ • Member แก้ไขหรือลบโพสต์ของตนเองได้ แต่ไม่สามารถแก้ไขหรือลบโพสต์ของผู้อื่น • Community Owner สามารถลบโพสต์ของผู้อื่นได้เฉพาะโพสต์ที่อยู่ภายใน Community ที่ตนเองเป็นเจ้าของ และ Admin สามารถจัดการโพสต์ทั้งหมดได้
Security Requirements	• ตรวจสอบ Ownership, สิทธิ์ Community Owner ของ Community นั้น หรือสิทธิ์ Admin ก่อนแก้ไขหรือลบโพสต์ • ตรวจสอบและกรองข้อมูลที่รับเข้าระบบ เพื่อป้องกัน XSS • ตรวจสอบสิทธิ์การเข้าถึงโพสต์ที่อยู่ภายใน Community ตามสถานะ Public/Private

6.5 Feed Module

ขอบเขตการทำงาน	View Feed, View Post List, Display Latest Posts, Display Posts from Followed Users
Access Policy	• Member, Community Owner และ Admin สามารถดู Feed ที่เป็น Public และโพสต์จากผู้ใช้ที่ติดตามได้ • การแสดงผล Feed ต้องตรวจสอบสิทธิ์ตามสถานะสมาชิกของแต่ละ Community และการตั้งค่าระบบ • ต้องตรวจสอบสถานะของ Community และ Post ก่อนแสดงผล และไม่แสดงข้อมูล Private ให้ผู้ไม่มีสิทธิ์

Security Requirements	• ตรวจสอบสิทธิ์การเข้าถึงก่อนดึงข้อมูลจากฐานข้อมูล • จำกัดจำนวนข้อมูลที่แสดงต่อ Request (Pagination) • ป้องกันการเปิดเผยข้อมูลที่ไม่เป็นสาธารณะปะปนใน Feed

6.6 Follow Module

ขอบเขตการทำงาน	Follow User, Unfollow User, View Followers, View Following
Access Policy	• เฉพาะผู้ใช้งานที่เข้าสู่ระบบแล้ว (Member, Community Owner และ Admin) สามารถ Follow ได้ • ผู้ใช้งานสามารถ Unfollow เฉพาะความสัมพันธ์ที่ตนเองเป็นผู้สร้างได้ • ห้ามสร้างความสัมพันธ์ติดตามซ้ำ และไม่อนุญาตให้ผู้ใช้งานติดตามตนเอง
Security Requirements	• ตรวจสอบ Authentication ก่อนดำเนินการ และตรวจสอบความถูกต้องของ User ID เป้าหมาย • ป้องกันการสร้างข้อมูล Follow ซ้ำ • ตรวจสอบ Ownership ก่อนดำเนินการ Unfollow

6.7 Like Module

ขอบเขตการทำงาน	Like Post, Unlike Post, View Like Count, View Users Who Liked Post
Access Policy	• เฉพาะผู้ใช้งานที่เข้าสู่ระบบแล้ว (Member, Community Owner และ Admin) สามารถ Like ได้ และยกเลิกเฉพาะรายการ Like ของตนเอง • ไม่อนุญาตให้สร้าง Like ซ้ำในโพสต์เดียวกัน • การดูรายชื่อผู้กด Like ต้องเป็นไปตามสิทธิ์การเข้าถึงโพสต์นั้น
Security Requirements	• ตรวจสอบ Authentication ก่อน Like และตรวจสอบว่า Post มีอยู่จริง • ป้องกันการกด Like ซ้ำด้วยเงื่อนไขระดับ Logic และ Database Constraint • ตรวจสอบ Ownership ก่อนดำเนินการ Unlike

6.8 Comment Module

ขอบเขตการทำงาน	Create Comment, View Comment, Edit Comment, Delete Comment, View Comment List
Access Policy	• เฉพาะผู้ใช้งานที่เข้าสู่ระบบแล้ว (Member, Community Owner และ Admin) สามารถแสดงความคิดเห็นได้ • Member แก้ไขหรือลบความคิดเห็นของตนเองได้ แต่ไม่สามารถแก้ไขหรือลบความคิดเห็นของผู้อื่น • Community Owner สามารถลบความคิดเห็นที่ไม่เหมาะสมของผู้อื่นได้เฉพาะภายใน Community ที่ตนเองเป็นเจ้าของ และ Admin สามารถจัดการความคิดเห็นทั้งหมดได้
Security Requirements	• ตรวจสอบ Authentication ก่อนสร้าง Comment และตรวจสอบ Ownership, สิทธิ์ Community Owner หรือสิทธิ์ Admin ก่อนแก้ไขหรือลบ • ตรวจสอบความยาวและเนื้อหาของความคิดเห็น เพื่อป้องกัน XSS • ตรวจสอบสิทธิ์ในการเข้าถึง Post ก่อนอนุญาตให้แสดงความคิดเห็น

6.9 Media Module

ขอบเขตการทำงาน	Upload Image, View Image, Update Image, Delete Image
Access Policy	• Member, Community Owner และ Admin สามารถอัปโหลด เปลี่ยน หรือลบรูปภาพในบัญชีของตนเองได้ • ไม่อนุญาตให้เปลี่ยนหรือลบไฟล์ของผู้อื่น ยกเว้น Admin ตามนโยบายระบบ • การเข้าถึงไฟล์ต้องเป็นไปตามนโยบาย Public/Private
Security Requirements	• ตรวจสอบชนิดไฟล์และขนาดไฟล์ โดยตรวจสอบจากเนื้อหาจริง (MIME / Magic Bytes) ไม่พึ่งพาเพียงนามสกุล • กำหนดชื่อไฟล์ที่ปลอดภัย (Random / Sanitized Filename) • จำกัดสิทธิ์ในการเปลี่ยนหรือลบไฟล์ และไม่เปิดเผยไฟล์ส่วนตัวโดยไม่มีการตรวจสอบสิทธิ์

7. API Access Control

ตารางต่อไปนี้กำหนดสิทธิ์การเข้าถึง API ของแต่ละ Module สำหรับใช้ตรวจสอบและควบคุมสิทธิ์ในระดับ Endpoint โดยรองรับผู้ใช้งาน 3 ประเภท คือ **Member**, **Community Owner** และ **Admin**

7.1 Authentication API

Method	Endpoint	Function	Access Control	เงื่อนไข
POST	`/api/register/`	สมัครสมาชิก	Unauthenticated (ก่อนเป็น Member)	ตรวจสอบข้อมูลสมัครสมาชิก
POST	`/api/login/`	เข้าสู่ระบบ	Member / Community Owner / Admin	ตรวจสอบบัญชีและรหัสผ่าน
POST	`/api/logout/`	ออกจากระบบ	Member / Community Owner / Admin	ต้องเป็น Session ของตนเอง

7.2 User / Profile API

Method	Endpoint	Function	Access Control	เงื่อนไข
GET	`/api/profile/`	ดูโปรไฟล์ตนเอง	Member / Community Owner / Admin	ต้องเข้าสู่ระบบ
PATCH	`/api/profile/`	แก้ไขโปรไฟล์	Owner (Member / Community Owner / Admin)	แก้ไขข้อมูลของตนเองเท่านั้น
GET	`/api/users/{id}/`	ดูโปรไฟล์ผู้ใช้อื่น	Member / Community Owner / Admin	แสดงเฉพาะข้อมูลที่เปิดเผยได้
PATCH	`/api/users/{id}/`	แก้ไขโปรไฟล์ผู้ใช้	Owner / Admin	ต้องตรวจสอบ Ownership

7.3 Community API

Method	Endpoint	Function	Access Control	เงื่อนไข
GET	`/api/communities/`	ดูรายการ Community	Member / Community Owner / Admin	แสดงเฉพาะ Community ที่เข้าถึงได้
POST	`/api/communities/`	สร้าง Community	Member / Admin	ต้องเข้าสู่ระบบ (ผู้สร้างจะเป็น Community Owner)
GET	`/api/communities/{id}/`	ดูรายละเอียด Community	Member / Community Owner / Admin	ตรวจสอบสถานะ Public/Private
PATCH	`/api/communities/{id}/`	แก้ไข Community	Community Owner / Admin	ตรวจสอบ Ownership
DELETE	`/api/communities/{id}/`	ลบ Community	Community Owner / Admin	ตรวจสอบสิทธิ์ก่อนลบ

7.4 Post / Feed API

Method	Endpoint	Function	Access Control	เงื่อนไข
GET	`/api/posts/`	ดูรายการโพสต์	Member / Community Owner / Admin	ตรวจสอบสถานะโพสต์
POST	`/api/posts/`	สร้างโพสต์	Member / Community Owner / Admin	ต้องเข้าสู่ระบบ
GET	`/api/posts/{id}/`	ดูรายละเอียดโพสต์	Member / Community Owner / Admin	ตรวจสอบสิทธิ์การเข้าถึง
PATCH	`/api/posts/{id}/`	แก้ไขโพสต์	Post Owner / Admin	ต้องเป็นเจ้าของโพสต์
DELETE	`/api/posts/{id}/`	ลบโพสต์	Post Owner / Community Owner / Admin	เจ้าของโพสต์, Community Owner ภายใน Community ของตน หรือ Admin
GET	`/api/feed/`	ดู Feed	Member / Community Owner / Admin	กรองข้อมูลตามสิทธิ์

7.5 Follow API

Method	Endpoint	Function	Access Control	เงื่อนไข
POST	`/api/users/{id}/follow/`	ติดตามผู้ใช้งาน	Member / Community Owner / Admin	ห้ามติดตามตนเองหรือสร้างข้อมูลซ้ำ
DELETE	`/api/users/{id}/follow/`	เลิกติดตาม	Relationship Owner / Admin	ต้องเป็นผู้สร้างความสัมพันธ์
GET	`/api/users/{id}/followers/`	ดูรายชื่อ Followers	Member / Community Owner / Admin	ตรวจสอบการเปิดเผยข้อมูล
GET	`/api/users/{id}/following/`	ดูรายชื่อ Following	Member / Community Owner / Admin	ตรวจสอบการเปิดเผยข้อมูล

7.6 Like API

Method	Endpoint	Function	Access Control	เงื่อนไข
POST	`/api/posts/{id}/like/`	กด Like	Member / Community Owner / Admin	ต้องเข้าสู่ระบบและตรวจสอบ Post
DELETE	`/api/posts/{id}/like/`	ยกเลิก Like	Like Owner / Admin	ยกเลิกเฉพาะ Like ของตนเอง
GET	`/api/posts/{id}/likes/`	ดูจำนวนและรายการ Like	Member / Community Owner / Admin	ตรวจสอบสิทธิ์การเข้าถึง Post

7.7 Comment API

Method	Endpoint	Function	Access Control	เงื่อนไข
GET	`/api/posts/{id}/comments/`	ดูความคิดเห็น	Member / Community Owner / Admin	ตรวจสอบสิทธิ์การเข้าถึง Post
POST	`/api/posts/{id}/comments/`	แสดงความคิดเห็น	Member / Community Owner / Admin	ต้องเข้าสู่ระบบ
PATCH	`/api/comments/{id}/`	แก้ไขความคิดเห็น	Comment Owner / Admin	ตรวจสอบ Ownership
DELETE	`/api/comments/{id}/`	ลบความคิดเห็น	Comment Owner / Community Owner / Admin	เจ้าของความคิดเห็น, Community Owner ภายใน Community ของตน หรือ Admin

7.8 Media API

Method	Endpoint	Function	Access Control	เงื่อนไข
POST	`/api/media/upload/`	อัปโหลดไฟล์	Member / Community Owner / Admin	ตรวจสอบชนิดและขนาดไฟล์
GET	`/api/media/{id}/`	ดูไฟล์	Member / Community Owner / Admin	ตรวจสอบสิทธิ์การเข้าถึง
PATCH	`/api/media/{id}/`	เปลี่ยนข้อมูลไฟล์	Owner / Admin	ตรวจสอบ Ownership
DELETE	`/api/media/{id}/`	ลบไฟล์	Owner / Admin	ตรวจสอบสิทธิ์ก่อนลบ

หมายเหตุสำคัญในการพัฒนา API

ข้อที่	ข้อกำหนดด้านความปลอดภัยและการตรวจสอบ
1	ตรวจสอบความสอดคล้องของ URL Routing ใน `urls.py`, Views, Serializers และ Models ก่อนนำไปพัฒนา
2	การตรวจสอบสิทธิ์ (Authentication & Authorization) ต้องทำที่ฝั่ง Backend ทุกครั้ง
3	API ที่รับพารามิเตอร์ ID ของผู้ใช้งานหรือข้อมูลอื่นต้องตรวจสอบสิทธิ์เพื่อป้องกันช่องโหว่ IDOR
4	การตอบกลับ (API Response) ต้องไม่เปิดเผยข้อมูลสำคัญ เช่น Password Hash, Secret Key หรือข้อมูลภายในระบบ

Document Update: Version 1.4 (3 User Roles: Member, Community Owner & Admin) | Status: Active Specification for Development Team | Scope: Asset List, System Architecture, ACL, Module Access Control และ API Access Control